

Active recon по домену macpaw.com

1. Пошук security.txt

```
Contact: mailto:security@macpaw.com
Expires: 2026-03-01T02:07:00Z
Policy: https://macpaw.com/vulnerability-disclosure-policy
Preferred-Languages: en
```

2. DNSSEC Аналіз



Domain Name:

Analyzing DNSSEC problems for macpaw.com

.	✓ Found 3 DNSKEY records for . ✓ DS=20326/SHA-256 verifies DNSKEY=20326/SEP ✓ Found 1 RRSIGs over DNSKEY RRset ✓ RRSIG=20326 and DNSKEY=20326/SEP verifies the DNSKEY RRset
com	✓ Found 1 DS records for com in the . zone ✓ DS=19718/SHA-256 has algorithm ECDsap256SHA256 ✓ Found 1 RRSIGs over DS RRset ✓ RRSIG=61809 and DNSKEY=61809 verifies the DS RRset ✓ Found 2 DNSKEY records for com ✓ DS=19718/SHA-256 verifies DNSKEY=19718/SEP ✓ Found 1 RRSIGs over DNSKEY RRset ✓ RRSIG=19718 and DNSKEY=19718/SEP verifies the DNSKEY RRset
macpaw.com	✗ No DS records found for macpaw.com in the com zone ✗ No DNSKEY records found ✓ ajay.ns.cloudflare.com is authoritative for macpaw.com ✓ macpaw.com A RR has value 104.18.40.154 ✗ No RRSIGs found
macpaw.com	✓ elma.ns.cloudflare.com is authoritative for macpaw.com ✓ macpaw.com A RR has value 104.18.40.154 ✗ No RRSIGs found

- “No DS records found for macpaw.com in the com zone” — означає, що домен **macpaw.com** не має DS-запису (delegation signer record). Це означає, що він не підключений до ланцюжка DNSSEC-захисту.

- "No DNSKEY records found" — сам домен не має власних ключів для підпису DNS-записів.
- "No RRSIGs found" — його записи не підписані криптографічно.

Відсутність DNSSEC створює потенційну вразливість до MITM атак та DNS cache poisoning.

3. Subdomain enumeration

Результати скану з securitytrails.com

Domain	Rank	Hosting Provider
macpaw.com	12,744	Cloudflare, Inc.
research.marpaw.com	3,306,648	Cloudflare, Inc.
fixel.marpaw.com	3,809,440	Amazon.com, Inc.
cleanmymac.marpaw.com	4,443,228	Cloudflare, Inc.
gemini.marpaw.com	4,805,343	Cloudflare, Inc.
humanitarian-aid.marpaw.com	5,081,900	Cloudflare, Inc.
cmm.marpaw.com	6,426,559	Cloudflare, Inc.
cdn2.marpaw.com	7,266,136	Cloudflare, Inc.
blog.marpaw.com	7,749,728	-
cdn2-imgix.marpaw.com	7,932,160	Cloudflare, Inc.
cdn.marpaw.com	8,243,516	Cloudflare, Inc.
news.marpaw.com		Cloudflare, Inc.
ns2.marpaw.com		-
resellers-proxy.marpaw.com		Cloudflare, Inc.
ft-moonlock.marpaw.com		Google LLC

Результати скану з kноскру



clearvpn.macpaw.com ['172.64.147.102', '104.18.40.154']

http [403, None, 'cloudflare']

https [301, 'https://clearvpn.com', 'cloudflare']

cert [None, None, None]

auth.macpaw.com ['104.18.40.154', '172.64.147.102']

http [403, None, 'cloudflare']

https [200, None, 'cloudflare']

cert [None, None, None]

cdn-panther.macpaw.com ['172.64.147.102', '104.18.40.154']

http [403, None, 'cloudflare']

https [404, None, 'cloudflare']

cert [None, None, None]

app-info.macpaw.com ['104.18.40.154', '172.64.147.102']

http [403, None, 'cloudflare']

https [404, None, 'cloudflare']

cert [None, None, None]

analytics.macpaw.com ['172.64.147.102', '104.18.40.154']

http [403, None, 'cloudflare']

https [404, None, 'cloudflare']

cert [None, None, None]

cleanmymac.macpaw.com ['104.18.40.154', '172.64.147.102']

http [403, None, 'cloudflare']

https [200, None, 'cloudflare']

cert [None, None, None]

33523513.macpaw.com ['104.18.40.154', '172.64.147.102']

http [403, None, 'cloudflare']

https [404, None, 'cloudflare']

cert [None, None, None]

app.macpaw.com ['104.18.40.154', '172.64.147.102']

http [403, None, 'cloudflare']

https [403, None, 'cloudflare']

cert [None, None, None]

admin-prod-clearvpn.macpaw.com ['104.18.40.154', '172.64.147.102']

http [403, None, 'cloudflare']

https [403, None, 'cloudflare']

cert [None, None, None]

admin-stage-clearvpn.macpaw.com ['104.18.40.154',
'172.64.147.102']

```
http [403, None, 'cloudflare']
https [403, None, 'cloudflare']
cert [None, None, None]
api-lytics.macpaw.com ['104.18.40.154', '172.64.147.102']
http [403, None, 'cloudflare']
https [200, None, 'cloudflare']
cert [None, None, None]
api.panther.macpaw.com ['172.64.147.102', '104.18.40.154']
http [403, None, 'cloudflare']
https [404, None, 'cloudflare']
cert [None, None, None]
cmm.macpaw.com ['172.64.147.102', '104.18.40.154']
http [403, None, 'cloudflare']
https [200, None, 'cloudflare']
cert [None, None, None]
activation.macpaw.com ['104.18.40.154', '172.64.147.102']
http [403, None, 'cloudflare']
https [404, None, 'cloudflare']
cert [None, None, None]
cmm-promo.macpaw.com ['198.202.211.1']
http [301, 'https://cmm-promo.macpaw.com/', 'cloudflare']
https [200, None, 'cloudflare']
cert [None, None, None]
```

Багато під-доменів резолвяться на один і той самий IP (е.г. 104.18.40.154), що вказує на присутність Wildcard дозволу.

Маємо лише 2 збіги по першим 15 записам між Security Trails та kноскру. З чого можна зробити висновок, що дані з Security Trails не є актуальними.

4. Files and folders enumeration

Команда, що була використана для скану. (агресивніший скан страшно)

```
dirsearch -u https://macpaw.com -w ~/wordlists/top-100.txt -t 1 --delay 2 -
-random-agent --extensions=php,html,txt --timeout 8 --exclude-status=40
3,401,429
```

Результат роботи програми:

```
200 2KB https://macpaw.com/sitemap.xml
200 2KB https://macpaw.com/robots.txt
200 22KB https://macpaw.com/favicon.ico
200 149B https://macpaw.com/.well-known/security.txt
200 2KB https://macpaw.com/sitemap.xml.gz
301 318B https://macpaw.com/profile → REDIRECTS TO: https://macpaw.com
200 235KB https://macpaw.com/support
```

Інформації, що несла би потенційну небезпеку не було знайдено.

5. nmap

Команда, що використовувалась

```
nmap -sT --top-ports 200 -sV -T2 --scan-delay 200ms --max-retries 2 --open macpaw.com -oN 03_service_version.txt
```

Результат:

```
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy
8443/tcp   open  https-alt
```

6. Можливі вектори атаки

- DNS-cache poisoning. Домен не підписаний в ланцюжку DNSSEC. Можна було б спробувати перехопити трафік або перенаправити на фішинговий ресурс.
- Subdomain takeover через наявність wildcard правил.
- According to ChatGPT: Наявність **8080** і **8443** може вказувати на внутрішні адмін-панелі, проксі або альтернативні веб-сервіси. **http-proxy** на 8080 може бути **відкритим проксі**, що іноді дозволяє обходити обмеження або тестувати доступність.